

SWE308: Information Security

Lecture 11: Modular Exponentiation & Network Security - I

Dr Iftekhar Salam
iftekhar.salam@xmu.edu.my

Xiamen Univesity Malaysia

Presentation outline

- 1 Modular exponentiation
- 2 Firewalls
- 3 Anti-virus Software
- 4 Intrusion Detection Systems

Presentation Outline

- 1 Modular exponentiation
- 2 Firewalls
- 3 Anti-virus Software
- 4 Intrusion Detection Systems

Modular exponentiation for large numbers

Exponentiation property

- $A^B \bmod C = ((A \bmod C)^B) \bmod C$

Often we want to calculate $A^B \bmod C$ for large values of B

- Unfortunately, A^B becomes very large for even modest sized values for B
- For example:
 - $2^{90} = 1237940039285380274899124224$
- Some of these huge values cause our calculators and computers to return overflow errors
- Even if they didn't, it would take a long time to find the mod of these huge numbers directly

What can we do to to reduce the size of terms involved and make our calculation faster?

Suppose we want to calculate $2^{90} \bmod 13$, but we have a calculator that can't hold any numbers larger than 2^{50} .

Here is a simple divide and conquer strategy:

- Apply exponent rules to the smaller parts
 - $2^{90} = 2^{50} * 2^{40}$
 - Apply $\bmod C$ to each part where $C = 13$ for this example
 - $2^{50} \bmod 13 = 1125899906842624 \bmod 13 = 4$
 - $2^{40} \bmod 13 = 1099511627776 \bmod 13 = 3$
- Apply multiplication property and combine the parts
 - $2^{90} \bmod 13 = (2^{50} \times 2^{40}) \bmod 13$
 - $2^{90} \bmod 13 = (2^{50} \bmod 13 \times 2^{40} \bmod 13) \bmod 13$
 - $2^{90} \bmod 13 = (4 \times 3) \bmod 13$
 - $2^{90} \bmod 13 = 12 \bmod 13$
 - $2^{90} \bmod 13 = 12$

How can we calculate $(A^B \bmod C)$ quickly if B is a power of 2 ?

For instance, how could we calculate $7^{256} \bmod 13$ using a calculator that can't hold numbers larger than 7^{10} ?

- We could split 7^{256} into 25 parts of 7^{10} and 1 part of 7^6 , but this wouldn't be very efficient.
- There is a better way ...

Fast modular exponentiation

How can we calculate $(A^B \bmod C)$ quickly if B is a power of 2 ?

- Using modular multiplication rules:

- $A^2 \bmod C = (A \times A) \bmod C = ((A \bmod C) \times (A \bmod C)) \bmod C$
- We can use this to calculate $7^{256} \bmod 13$ quickly
 - $7^1 \bmod 13 = 7$
 - $7^2 \bmod 13 = (7^1 \times 7^1) \bmod 13 = (7^1 \bmod 13 \times 7^1 \bmod 13) \bmod 13$
 - We can substitute our previous result for $(7^1 \bmod 13)$ into this equation.
 - $7^2 \bmod 13 = (7 \times 7) \bmod 13 = 49 \bmod 13 = 10$
 - $7^4 \bmod 13 = (7^2 \times 7^2) \bmod 13 = (7^2 \bmod 13 \times 7^2 \bmod 13) \bmod 13$
 - We can substitute our previous result for $7^2 \bmod 13$ into this equation.
 - $7^4 \bmod 13 = (10 \times 10) \bmod 13 = 100 \bmod 13 = 9$
 - $7^8 \bmod 13 = (7^4 \times 7^4) \bmod 13 = (7^4 \bmod 13 \times 7^4 \bmod 13) \bmod 13$
 - We can substitute our previous result for $7^4 \bmod 13$ into this equation.
 - $7^8 \bmod 13 = (9 \times 9) \bmod 13 = 81 \bmod 13 = 3$
 - We continue in this manner, substituting previous results into our equations.
 - ...after 5 more iterations we hit:
 - $7^{256} \bmod 13 = (7^{128} \times 7^{128}) \bmod 13 = (7^{128} \bmod 13 \times 7^{128} \bmod 13) \bmod 13$
 - $7^{256} \bmod 13 = (3 \times 3) \bmod 13 = 9 \bmod 13 = 9$

Fast modular exponentiation

This has given us a method to calculate $A^B \bmod C$ quickly provided that B is a power of 2.

However, we also need a method for fast modular exponentiation when B is not a power of 2.

How can we calculate $A^B \bmod C$ quickly for any B ?

For example, we want to calculate $5^{117} \bmod 19$

- Step 1: Divide B into powers of 2 by writing it in binary
- Step 2: Calculate $\bmod C$ of the powers of two $\leq B$
- Step 3: Use modular multiplication properties to combine the calculated $\bmod C$ values

How can we calculate $A^B \bmod C$ quickly for any B ?

Step 1: Divide B into powers of 2 by writing it in binary

- For our example $B = 117$
- $117 = 1110101$ in binary
- Start at the rightmost digit, let $k = 0$ and for each digit
 - if the digit is 1, we need a part for 2^k , otherwise we do not
 - Add 1 to k , and move left to the next digit

$$117 = (2^0 + 2^2 + 2^4 + 2^5 + 2^6)$$

$$117 = 1 + 4 + 16 + 32 + 64$$

$$5^{117} \bmod 19 = 5^{(1 + 4 + 16 + 32 + 64)} \bmod 19$$

$$5^{117} \bmod 19 = (5^1 * 5^4 * 5^{16} * 5^{32} * 5^{64}) \bmod 19$$

How can we calculate $A^B \bmod C$ quickly for any B ?

Step 2: Calculate $\bmod C$ of the powers of two $\leq B$

$$5^1 \bmod 19 = 5$$

$$5^2 \bmod 19 = (5^1 \times 5^1) \bmod 19 = (5^1 \bmod 19 \times 5^1 \bmod 19) \bmod 19$$

$$5^2 \bmod 19 = (5 \times 5) \bmod 19 = 25 \bmod 19$$

$$5^2 \bmod 19 = 6$$

$$5^4 \bmod 19 = (5^2 \times 5^2) \bmod 19 = (5^2 \bmod 19 \times 5^2 \bmod 19) \bmod 19$$

$$5^4 \bmod 19 = (6 \times 6) \bmod 19 = 36 \bmod 19$$

$$5^4 \bmod 19 = 17$$

$$5^8 \bmod 19 = (5^4 \times 5^4) \bmod 19 = (5^4 \bmod 19 \times 5^4 \bmod 19) \bmod 19$$

$$5^8 \bmod 19 = (17 \times 17) \bmod 19 = 289 \bmod 19$$

$$5^8 \bmod 19 = 4$$

How can we calculate $A^B \bmod C$ quickly for any B ?

Step 2: Calculate $\bmod C$ of the powers of two $\leq B$ (Continued from previous slide)

$$5^{16} \bmod 19 = (5^8 \times 5^8) \bmod 19 = (5^8 \bmod 19 \times 5^8 \bmod 19) \bmod 19$$

$$5^{16} \bmod 19 = (4 \times 4) \bmod 19 = 16 \bmod 19$$

$$5^{16} \bmod 19 = 16$$

$$5^{32} \bmod 19 = (5^{16} \times 5^{16}) \bmod 19 = (5^{16} \bmod 19 \times 5^{16} \bmod 19) \bmod 19$$

$$5^{32} \bmod 19 = (16 \times 16) \bmod 19 = 256 \bmod 19$$

$$5^{32} \bmod 19 = 9$$

$$5^{64} \bmod 19 = (5^{32} \times 5^{32}) \bmod 19 = (5^{32} \bmod 19 \times 5^{32} \bmod 19) \bmod 19$$

$$5^{64} \bmod 19 = (9 \times 9) \bmod 19 = 81 \bmod 19$$

$$5^{64} \bmod 19 = 5$$

How can we calculate $A^B \bmod C$ quickly for any B ?

Step 3: Use modular multiplication properties to combine the calculated $\bmod C$ values

$$5^{117} \bmod 19 = (5^1 \times 5^4 \times 5^{16} \times 5^{32} \times 5^{64}) \bmod 19$$

$$5^{117} \bmod 19 = (5^1 \bmod 19 \times 5^4 \bmod 19 \times 5^{16} \bmod 19 \times 5^{32} \bmod 19 \times 5^{64} \bmod 19) \bmod 19$$

$$5^{117} \bmod 19 = (5 \times 17 \times 16 \times 9 \times 5) \bmod 19$$

$$5^{117} \bmod 19 = 61200 \bmod 19 = 1$$

$$5^{117} \bmod 19 = 1$$

More practices

Compute $3^{97} \bmod 353$

Compute $3^{233} \bmod 353$

Compute $3^{64} \bmod 23$

Presentation Outline

- 1 Modular exponentiation
- 2 **Firewalls**
- 3 Anti-virus Software
- 4 Intrusion Detection Systems

What is a Firewall?

Component or set of components

- placed at interface between two networks with differing security requirements
- aim to control the flow (inbound and outbound) of network traffic between networks

All messages entering or leaving the protected network pass through firewall

- Each message is examined:
 - If they do not meet specified security criteria, they are blocked
 - NEED TO HAVE SECURITY POLICY
 - To **protect** private networks and individual devices from the dangers of the Internet
 - To filter incoming or outgoing traffic based on a predefined set of rules called firewall policies

Implemented in hardware, software, or combination

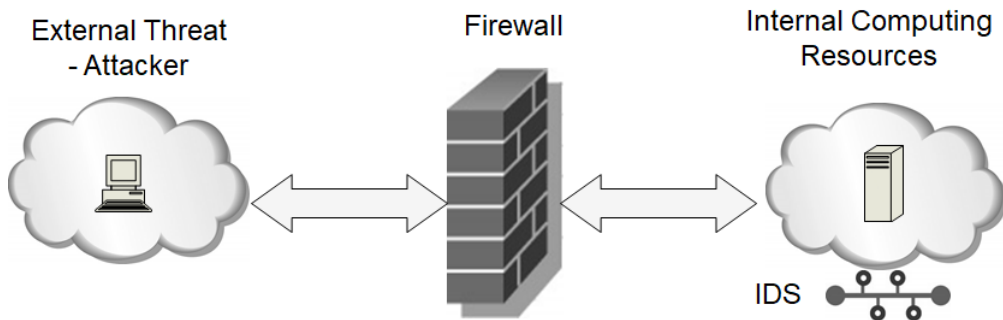
What is a Firewall?



Firewalls in a Computer Network

Frequently used to prevent unauthorized Internet users from accessing private networks (Intranet)

- Aim to protect internal information system against attack initiated from the outside network
- Want to block communication (in or out) that is malicious, risky, or just unnecessary



Firewall Policies: Approaches

Two approaches to creating firewall policies

- Blacklist approach (default-allow)
 - All packets are allowed except those that satisfy rules defined specifically in a blacklist
 - **Pros:** Flexible in ensuring that service to the internal network is not disrupted by the firewall
 - **Cons:** Unexpected forms of malicious traffic could go through
- Whitelist approach (default-deny)
 - Packets are dropped or rejected unless they are specifically allowed by the firewall
 - **Pros:** A safer approach to defining a firewall ruleset
 - **Cons:** Must consider all possible legitimate traffic in rulesets

Types of Firewall

Firewall categories: Two criteria used to categorise:

- ① highest layer data in (OSI or TCP/IP) network communication protocol stack the firewall can examine;
- ② Whether communication terminates at the firewall:
 - Connection does not terminate: firewall is a **filter**
 - Connection does terminate: firewall is a **proxy**

Examples:

- Simple packet filters operate at network level and examine data of lower TCP/IP layers only
- Application level gateway - more sophisticated, can examine application layer data

Firewall: Filter

Packet filter:

- device or program that operates at the network layer
- require a set of rules that specify what action to take for a given set of conditions
 - Two possible actions: **allow** or **block**
 - Rules should be consistent with organisation's information security policy
- decides whether to **allow** or **block** each packet based on information in packet headers, such as:
 - IP header fields (Source or Destination IP Addresses)
 - The Protocol (UDP, TCP or ICMP)
 - TCP/UDP port numbers (Source or Destination Port Number)
 - Direction the packet is travelling (into/out of internal network)

Firewall: Simple Packet Filter

Simple packet filters

- examine each packet independently of other packets,
- even if they are part of the same connection

A rule table specifies how to filter network traffic:

- Each rule consists of conditions and an action
- For each packet, the first matching rule is found
- Two possible actions: **allow** or **block**

Example rule table: inbound traffic to email (SMTP) server 1.2.3.10

Protocol	Src IP	Src port	Dst IP	Dst port	Action	Comment
TCP	4.5.6.7	*	1.2.3.10	25	Block	Stop this spammer
TCP	*	*	1.2.3.10	25	Allow	Inbound SMTP
TCP	1.2.3.10	25	*	*	Allow	SMTP responses
*	*	*	*	*	Block	Default rule

Firewall: Stateful Packet Filter

Stateful Packet Filter

- Use same mechanism as simple packet filters
 - examine packet headers & compare to a ruleset
- **BUT** stateful more 'intelligent' than simple:
 - Also keep a 'state table' noting the state of each connection:
 - established, in use, or terminated?
 - Examine the state:
 - If header values contradict expected state, packet dropped
 - Sometimes called **dynamic** packet filters:
 - Recognise an outgoing connection request from internal client to an external server,
 - Add temporary rule to allow reply traffic through firewall
 - When session is finished, the temporary rule is deleted

Stateful Firewall

IF (packet belongs to an existing “association”)

- THEN accept packet
- ELSE check firewall rules;
 - IF (packet may pass)
 - THEN store “association” in state table
 - ELSE discard packet

Associations may be

- TCP connections
- UDP flows
- ICMP request/response pairs

Firewall: Packet Filter

Strengths:

- Low overhead and high throughput
- Operate at lower layers, so support almost any application

Weaknesses:

- Do not examine application layer data/commands
 - May allow insecure operations to occur
 - Cannot perform content filtering or user authentication
- Allow direct connections between hosts inside & outside firewall
- Simple (stateless) packet filters
 - may be susceptible to IP spoofing
 - more difficult to write complex rules

Firewall: Application Proxy Gateway

Application Proxy Gateway:

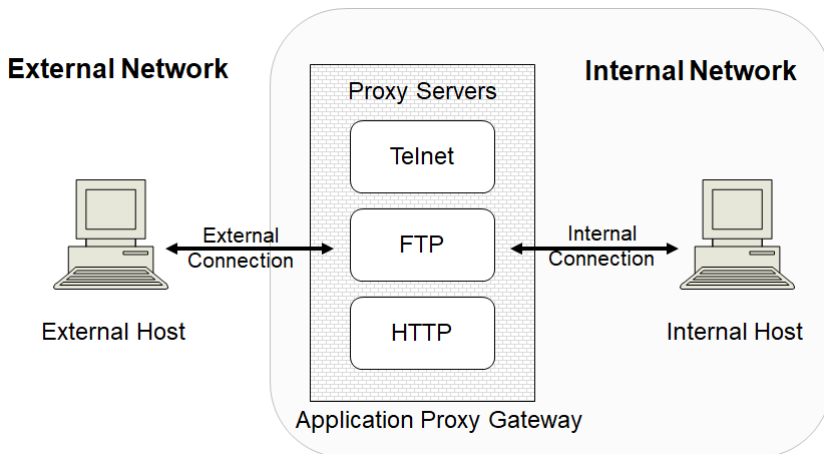
- filters traffic based on application data & header info
- known as a **proxy** because firewall **acts on behalf of the client**
 - Instead of a direct connection from client to server, all connections terminate on the firewall
- Two connections are made
 - connection from client to proxy and,
 - (if request permitted) connection from proxy to requested destination
 - The proxy:
 - accepts the incoming connection,
 - analyzes contents of packet and protocol to be used,
 - determines if rules allow connection and,
 - if connection is permitted, initiates a connection

Firewall: Application Proxy Gateway

Usually support only specific applications or specific features of an application:

- Each application (email, web browser) must have its own proxy (specific gateway) in the firewall
- understands whether the traffic flowing is following the protocol for that application and allowed by the policy rules

Application layer firewalls have proxies for most commonly used protocols



Firewall: Application Proxy Gateway

Strengths:

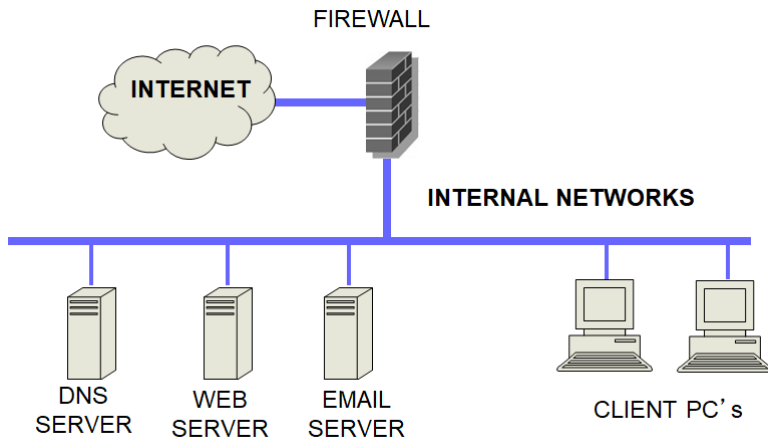
- Provides potential for better security through control of application layer data/commands
- Allows content filtering and user authentication

Weaknesses:

- Slower than packet filters, so may be unsuitable for real-time applications
- Limited support for new applications until vendor writes new gateways for new applications
- Requires one additional connection for each new connection

Firewalls: location

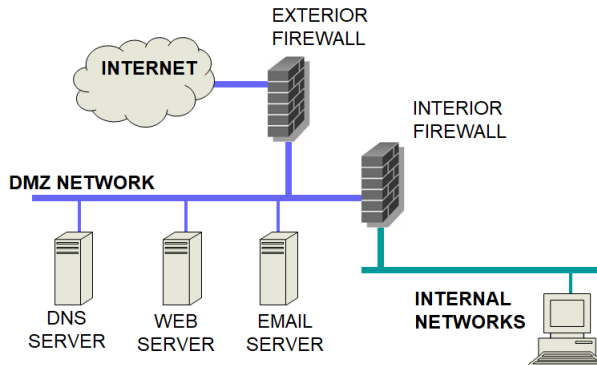
Simple Firewall Architecture



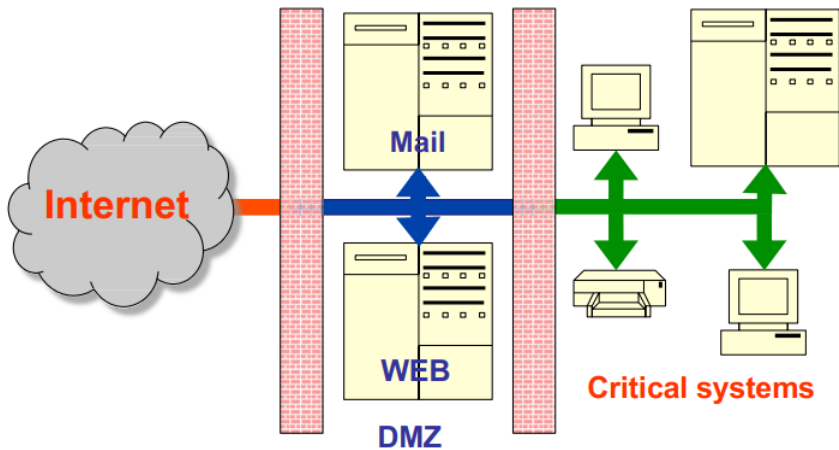
Firewalls: location

DMZ Architecture

- Two firewalls: one external and one internal
- DMZ is an area in between these two
- Can put assets in there that requires external connectivity but introduce risk
 - email server, web server etc
- Can configure internal and external firewalls differently, depending on the organisation's requirements, to provide greater degree of protection for critical assets.



DMZ Architecture



Firewall Issues

For a firewall to be effective, it must be:

- set up to implement a well formulated security policy
- effectively administered,
- updated with the latest patches, and
- monitored

The security policy must clearly state the organisation's definition of acceptable traffic

- everything else is considered unacceptable and must be blocked

Filtering should be performed on traffic in both directions:

- Outbound connections should be filtered to prevent:
 - internal users accessing untrusted services or dangerous content
 - compromised internal machines exfiltrating data, spreading viruses to the Internet, or being used as part of distributed attacks on other systems

Firewall Issues

Firewall rules can be difficult to configure:

- Order of rules matters
- Configurations are usually fragile
- Administrators can be afraid to modify configurations in case something breaks

Using firewalls to provide perimeter defence has serious limitations:

- Errors in firewall configuration are common
- Large networks may have compromised nodes inside
- Many new applications 'bypass' firewalls by masquerading as web traffic, using TCP port 80 and 443
 - For example: skype, bittorrent

Complement firewall use with other defensive measures

Presentation Outline

- 1 Modular exponentiation
- 2 Firewalls
- 3 Anti-virus Software**
- 4 Intrusion Detection Systems

Anti-virus

Defensive measure:

- Intended to prevent malicious software harming information assets
- Ideal: prevent malicious software getting in to system
- Reality: prevention not possible all the time

Need capability to:

- Detect
- Identify
- Remove

Malicious Software

Malicious Software: Malware

- programs that exploit system vulnerabilities
- deliberately crafted to achieve some effect
 - Not intended or desired by system owner

Multiple types and propagation strategies

May utilise techniques to hide themselves

Viruses

Virus:

- Malicious software that infects programs (host)
- Modifies host program to include a copy of the virus
 - then executes secretly when host program is run
- Usually specific to operating system
 - taking advantage of their details and vulnerabilities

A typical virus goes through 4 phases:

- Dormant: idle (not found in all viruses)
- Propagation: copy itself into other programs/disk areas
- Triggering: activated (date, file, disk limit)
- Execution: perform the intended function
 - Display message, compromise other files (CIA), ...

Viruses: Propagation Phase

Using infected programs:

- the virus is executed every time the program is executed
- Using interrupts that occur each time an external disk drive or a DVD is inserted into a USB port:
 - Once this interrupt occurs, the virus is executed as part of the interrupt-handling routine and it tries to infect the newly inserted volume
- As an email attachment
- Through infected software
 - Embed a virus or a Trojan horse in a useful program (a calculator, nice clock, or beautiful screen saver, ...)

Viruses: Triggering

Any event can be used as a trigger by a virus:

- Date or time
- Number of boots
- Number of key-presses on the keyboard
- Amount of free space on the hard drive
- Amount of minutes the machine has been idle
- User interaction with program: click or open

Viruses: Execution

Virus Payload:

- the malicious “task” of the software
- Performed when triggering condition is satisfied

Examples:

- Display a message
- Read a certain sensitive or private file
- Slow the computer down by monopolizing and exhausting limited resources
- Completely deny any services to the user
- Erase all the files on the host computer
- Select some files at random and change several bits in each file, also at random
 - referred to as data diddling
 - serious, because it results in problems that seem to be caused by hardware failures, not by a virus
- Random change of permissions
- Produce sounds, animation

Classic Virus Example

Melissa – 1999

- Spread by email
- exploited MS Word macro in doc attachment
- if attachment opened, macro activates
- sends email to all on users address list
- and does local damage

Current malware trend:

- Macros are being heavily utilised
- Microsoft: We're fighting Windows malware spread via Excel in email with bad macro
- Published: June 24 2019

Source: <https://www.zdnet.com/article/microsoft-were-fighting-windows-malware-spread-via-excel-in-email-with-bad-macro/>

Current Malware Trends

Multipurpose Malware:

- Take control of your computer,
 - You could become a bot in a bot-net
 - Might be used in DDoS against someone else
- Keystroke logging
 - Gain credentials to access other accounts

Ransomware:

- Huge threat – as discussed previously
- WannaCry – May 2017,
- Petya - June 2017 ,
- NamPoHyu Virus aka MegaLocker - April 2019,
- Sodinokibi Ransomware - April 2019

Anti-Virus (AVS) Software

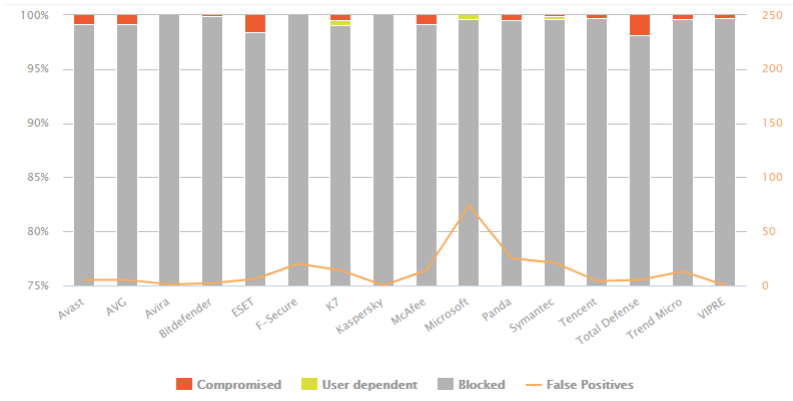
Antivirus software tries to identify malware by:

- Signatures:
 - Matching with a signature of a file from a database of known malware
 - Keep AVS up to date to detect newer malware
- Heuristics:
 - Partial matching with existing signatures, allows for variations in the files, sometimes deliberately inserted to obfuscate

Anti-virus Software

No antivirus software will be 100% effective

- AV comparatives independent testing for February – May 2019 (752 Test cases) has most test results at 90% plus
- See: www.av-comparatives.org/dynamic-tests/formonthlyandquarterlyreports



Presentation Outline

- 1 Modular exponentiation
- 2 Firewalls
- 3 Anti-virus Software
- 4 **Intrusion Detection Systems**

Intrusion Detection Systems

IDS are automated systems that detect suspicious events

Two types:

① Host based

- designed to detect intrusions only on the host it is installed on
- monitor changes to host's operating system files and traffic sent to the host

② Network based

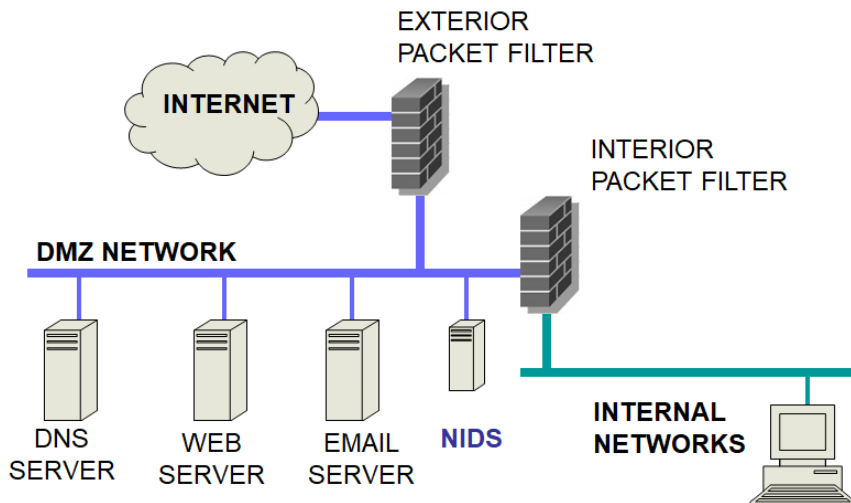
- designed to detect intrusions on one or more network segments, usually deployed to protect a number of hosts
- monitor networks looking for suspicious traffic

Network IDS Deployment

Network IDS (NIDS):

- needs to monitor traffic for the network/s it is protecting
 - Generally done by placing network interface card of IDS in 'promiscuous' mode to capture all network traffic that crosses its network segment (not just traffic destined for the IDS itself)
- Can enhance security provided by a firewall by adding another layer of defence
- Multiple IDS can be deployed on multiple networks and report to a central system

Network IDS Deployment



Intrusion Detection: Methods

Two main types of detection:

- ① Misuse detection
 - sometimes called Signature detection
 - Matches observed behaviour to known malicious behaviour
- ② Anomaly detection
 - Compares observed behaviour with known 'good' behaviour.
 - If they don't match, the behaviour is bad.

Both methods and combinations of methods in use

Misuse Based IDS

Advantages:

- Fast, only way to detect known intrusions at runtime
- More True Positive results than False Positive results

Disadvantages:

- Can't detect attacks that don't match existing signatures - so require constant signature updates
- Minor modifications to attack traffic can avoid detection
- In DoS attacks, the IDS can be overwhelmed

Anomaly Based IDS

Advantages:

- Can potentially detect new attacks by identifying unusual behaviour
- Information from anomaly based IDS can be used to develop signatures for misuse based IDS

Disadvantages:

- May generate many false positives (false alarms)
- Usually require a lot of tuning to develop models of 'normal' behaviour

Anomaly Modeling

Denning has identified three statistical models

- ① Threshold metric
- ② Statistical moments
- ③ Markov model

Threshold Metric

A minimum of m and a maximum of n events are expected to occur

- If outside bound, behavior deemed anomalous
- Determining the threshold requires different level of sophistication and characteristics of the users

Microsoft Windows NT 4.0 allows the system to lock a user out after some number n of failed login attempts. This is an intrusion detection system using the threshold metric with the lower limit 0 and the upper limit n . The attempted logins are deemed anomalous after n failed attempts to log in.

Statistical Moments

The analyzer uses mean and standard deviation, and possibly other means of correlation

- If behavior falls outside expected intervals, the behavior is deemed anomalous
- The system may evolve over time and the detection system need to take this changes into account to update by aging (or weighting) data or altering the statistical rule

Markov Model

Establish probabilities of one state transitioning to another state

- Get a sequence of event's probability
- When an event occurs that causes a transition that has a low probability, the event is deemed anomalous
- The model suggests that a notion of “state,” or past history, can be used to detect anomalies

Consider the sequence of events *abcdedeabcabc*.

$R_1 : ab \rightarrow c(1)$ $R_2 : c \rightarrow d(0.5)$ $R_3 : c \rightarrow a(0.5)$

$R_4 : d \rightarrow e(1)$ $R_5 : e \rightarrow a(0.5)$ $R_6 : e \rightarrow d(0.5)$

Rules R_1 and R_4 are good indicators of expected behavior. The other rules are not particularly good, and will either be dropped (should the probability decrease over time) or become better (should the probability increase over time).

The effectiveness of Markov-based models depends on the adequacy of the data used to establish the model

Major IDS Operational Issue

- IDS are widely deployed
- The rate of false positives can be problematic
 - Can lead to a sense of mistrust of IDS
 - Then apathy by security administrator
- Common IDS product:
 - Snort (open source NIDS)

Intrusion Detection vs Firewall

Firewall

- A firewall is a hardware and/or software which functions in a networked environment to block unauthorized access while permitting authorized communications
- Firewall is a device and/or a software that stands between a local network and the Internet, and filters traffic that might be harmful
- firewall can block connection
- e.g., Security personnel at the gate

Intrusion Detection

- An Intrusion Detection System (IDS) is a software or hardware device installed on the network (NIDS) or host (HIDS) to detect and report intrusion attempts to the network
- Intrusion Detection System (IDS) cannot block connection
- e.g., a security camera after the gate

Intrusion Prevention Systems

Most commonly, an IPS is a combination of an IDS and a firewall

- A system that aims to both detect and stop an attack

Can be application specific:

Can be an extension of an NIDS

Can be used to defend systems that cannot be patched

Summary

Firewalls:

- Perimeter defence, or segment
- Require understanding of security policy, not just technology

Malware and Anti-virus:

- Constantly changing environment
- Regular updating required

Intrusion detection:

- Consider method, rate of false positives and response

Defense in depth:

- Consider both perimeter and interior of network
- Use combination of security technologies

End of Lecture 11! 😊

Acknowledgment

- Khan academy for the slide related to modular exponentiation

Remember to complete you Quiz!

Next Week Lecture

- Network security-II
 - Network security protocols: HTTP authentication, TLS/SSL, IPSec, SSH,...

QUESTIONS?

Appendix: University's vision and mission

- ① Vision: Xiamen University Malaysia aspires to become a university with a distinct global outlook, featuring first-class teaching and research, and embracing cultural diversity.
- ② Mission: To nurture young talents with dignity and wisdom, turning them into fine citizens of the region who will contribute to the prosperity of the people and social progress of Malaysia, China and Southeast Asia.